

ISO/IEC 27001 : 2022 EDICIÓN 2026

LA GUÍA EJECUTIVA

Certificar la *confianza*.

Guía de referencia para CEOs, CTOs y CISOs de empresas tecnológicas que venden —o quieren vender— a corporativos, instituciones financieras y entidades del sector público sobre ISO/IEC 27001, el estándar internacional certificable para sistemas de gestión de seguridad de la información.

SELLO / REFERENCIA



CERTEZA HECHA NORMA.

ISO/IEC

27001

SISTEMA DE GESTIÓN
DE SEGURIDAD DE LA
INFORMACIÓN

COLOFÓN

Cerrar contratos. Proteger el negocio. *Certificar la confianza.*

Este documento ha sido preparado para ser leído como una conversación: rigurosa pero accesible, técnica pero útil.

EDICIÓN

2026 · v1.0 · Distribución pública

EDITOR

ONCE México · Organismo de certificación

AUDIENCIA

CEOs, CTOs, CISOs y equipos comerciales de empresas tecnológicas en LATAM

SITIO

oncemexico.org

© 2026 ONCE México. Todos los derechos reservados.
Queda prohibida su reproducción total o parcial sin autorización escrita del titular.

El contenido tiene fines informativos y educativos; no constituye asesoría legal, regulatoria, de cumplimiento ni de implementación para ninguna organización. Las referencias a costos, tiempos y resultados son estimaciones orientativas de referencia del mercado.

Nota de independencia. ONCE México es un organismo de certificación. Sus actividades de auditoría y certificación se mantienen independientes de cualquier actividad de formación, y ONCE México no diseña, implementa ni asesora la implementación de sistemas de gestión en las organizaciones que certifica, conforme a los principios de imparcialidad de ISO/IEC 17021-1.

CONTENIDO

El orden de las cosas.

Ocho capítulos que van del costo real de operar sin certificación a tres casos de transformación comercial en el mercado hispanohablante.

00	Introducción · <i>Por qué necesitas leer esto</i>	04 – 07
	La pregunta que nadie quiere responder · El filtro invisible · El costo de la inacción	
01	Qué es ISO 27001 — <i>y qué no es</i>	08 – 11
	Definición ejecutiva · Cronología · Tres mitos que frenan la decisión directiva	
02	Quién debe <i>certificarse</i>	12 – 15
	Cinco sectores con mayor urgencia · Criterios mínimos · Autodiagnóstico	
03	El costo real de <i>no certificarse</i>	16 – 19
	El filtro de descalificación automática · El cuello de botella que congela tus ventas · Los números exactos	
04	Los controles que <i>pide la norma</i>	20 – 24
	Cláusulas mandatorias · Anexo A · Las dos etapas de auditoría	
05	Roadmap de certificación a <i>5 meses</i>	25 – 27
	Las seis fases · Proyección de inversión · Equipo interno mínimo	
06	Cinco objeciones — <i>y cómo rebatirlas</i>	28 – 29
	Patrones de resistencia directiva observados en el mercado	
07	Escenarios ilustrativos de <i>mercado</i>	30 – 31
	SaaS en Guadalajara · Servicios TI en CDMX · Fintech en Monterrey	
→	Tus próximos pasos	32
	Tres rutas de acción según tu nivel de madurez · Sobre ONCE México	

INTRODUCCIÓN

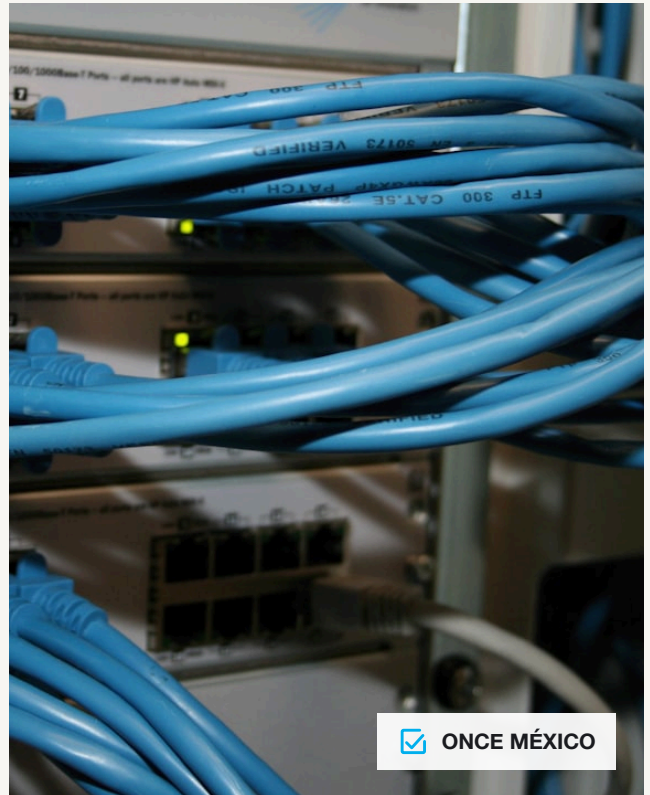
Por qué necesitas *leer esto.*

Imagina que tu empresa ganó la propuesta técnica. El cliente está convencido. El precio es competitivo. Entonces llega el correo del área de Compras:

"Antes de proceder al contrato, necesitamos su certificado ISO/IEC 27001 vigente emitido por un organismo acreditado."

¿Qué responde *tu equipo hoy?*

Si la respuesta es "no contamos con esa certificación", no estás solo. La gran mayoría de las empresas tecnológicas latinoamericanas que venden —o intentan vender— a corporativos, gobierno o instituciones financieras no tienen una respuesta institucional, documentada y externamente validada sobre cómo protegen la información de sus clientes.



 ONCE MÉXICO

Saben que sus sistemas son seguros. Pero no pueden demostrarlo con evidencia auditada por un tercero independiente. Esa brecha —entre "tenemos buenos controles" y "tenemos un sistema de gestión certificado"— es exactamente el problema que este ebook está diseñado para ayudarte a cerrar.

No con teoría abstracta. Con un marco internacional concreto, aplicable hoy, que transforma la ciberseguridad de un centro de costos defensivo en el **mayor habilitador comercial de tu organización.**

LA REALIDAD DEL MERCADO

La confianza ya no *se presume.*

La digitalización acelerada convirtió a los datos en el activo más valioso de cualquier organización. Y con eso llegó un cambio de paradigma irreversible en la manera en que los corporativos, bancos y entidades públicas seleccionan a sus proveedores tecnológicos.

Las revisiones improvisadas y las promesas verbales de seguridad quedaron obsoletas. Los compradores sofisticados exigen hoy **evidencias reales, estandarizadas y validadas por un tercero independiente acreditado.**

La confianza ya no se presume: debe ser auditada externamente.

52%

COMPRA CORPORATIVA

de los procesos de compra corporativa de tecnología exigen ISO 27001 de forma mandatoria, según investigaciones de Gartner.

80–90%

SECTORES REGULADOS

En sectores financiero, salud y gobierno, esa proporción se eleva entre el 80 y 90 % de las compras.

\$4.88M USD

COSTO POR BRECHA

Promedio global de una sola brecha de datos, según el *Cost of a Data Breach Report* de IBM. Una empresa tecnológica mediana puede no sobrevivirla.

→ **ESTE EBOOK ES TU MAPA PARA CONVERTIRTE EN UNA ORGANIZACIÓN CERTIFICADA Y COMERCIALMENTE COMPETITIVA.**

Qué es ISO 27001 — *y qué no es.*

Si le preguntas a diez directivos latinoamericanos qué evalúa exactamente ISO/IEC 27001, la mayoría te dará una respuesta incompleta. No porque sean negligentes — porque la norma tiene una percepción técnica que oculta su dimensión estratégica de negocio.

1.1

DEFINICIÓN EJECUTIVA

Lo que realmente hace la norma

Sin tecnicismo innecesario: SGSI traducido al lenguaje de negocios y la distinción fundamental entre tecnología y gobernanza.

1.2

CRONOLOGÍA

De dónde viene y por qué ahora

La evolución del estándar desde BS 7799 (1995) hasta la versión ISO/IEC 27001:2022 vigente.

1.3

DESMITIFICACIÓN

Tres mitos que frenan la adopción

Patrones de resistencia más frecuentes en los consejos directivos de empresas tecnológicas.

1.1 · DEFINICIÓN EJECUTIVA

Lo que realmente *hace la norma.*

ISO/IEC 27001 define los requisitos para que una organización establezca, implemente, mantenga y mejore continuamente un **Sistema de Gestión de Seguridad de la Información — SGSI**.

TRADUCIDO AL LENGUAJE DE NEGOCIOS

La norma te ayuda a documentar cómo tu empresa protege la información de sus clientes, empleados y operaciones: quién tiene acceso a qué, cómo se detectan y responden los incidentes, qué pasa cuando hay una brecha, y cómo garantizas que los riesgos están identificados, evaluados y tratados de forma continua.

LA DISTINCIÓN FUNDAMENTAL

*El objeto de la norma **no** es tu tecnología.
Es tu **gobernanza**.*

LO QUE NO EVALÚA

No evalúa si tu arquitectura cloud es la más avanzada del mercado. No mide el número de vulnerabilidades en tu código ni la velocidad de tus servidores.

Lo que evalúa es si tu organización tiene los procesos, políticas, roles y controles necesarios para **gestionar responsablemente la seguridad de la información** dentro de su alcance definido.

Una organización puede tener la infraestructura más sofisticada y reprobador la auditoría si no puede demostrar quién aprobó el control de accesos, cómo se monitorean los eventos y qué pasa cuando ocurre un incidente.

1.2 · CRONOLOGÍA

De dónde viene *y por qué ahora.*

La publicación de ISO/IEC 27001:2022 no fue un evento aislado. Fue la actualización estructurada de un estándar que lleva décadas siendo el referente global en gestión de seguridad de la información.

El eslabón que conecta el ecosistema.

ISO 27001 no opera en aislamiento. Es el centro de un ecosistema normativo que incluye **ISO 27701** para privacidad de datos, **ISO 42001** para gobernanza de IA, y marcos regulatorios como RGPD, PCI DSS y el EU AI Act. Quien tiene 27001 tiene la base estructural para todos los demás.

AÑO	HITO
1995	BS 7799 — Primera versión británica del estándar.
2005	ISO/IEC 27001:2005 — Primera edición internacional publicada por ISO.
2013	ISO/IEC 27001:2013 — Adopción de la Estructura de Alto Nivel (HLS).
2019	ISO/IEC 27701 — Extensión de privacidad y datos personales.
OCT · 2022	ISO/IEC 27001:2022 — Versión vigente. 93 controles reorganizados, 11 nuevos controles, mayor alineación con amenazas modernas como nube, DevSecOps y cadena de suministro digital.

1.3 · DESMITIFICACIÓN

Tres mitos que frenan la adopción.

La confusión alrededor de la norma no es accidental — es el resultado natural de una percepción técnica que oculta su valor comercial real. Estos son los tres malentendidos más frecuentes en las salas de dirección.

01 · EL MITO

"La certificación va a burocratizar nuestra empresa y frenará el desarrollo ágil de software."

LA REALIDAD

Este es el mito más extendido. La realidad operativa demuestra lo contrario: un SGSI bien estructurado **introduce orden y eficiencia**, reemplazando el caos improvisado por procesos previsibles y repetibles. La versión 2022 destaca por su flexibilidad y enfoque pragmático.

02 · EL MITO

"Es solo para grandes corporaciones con equipos de seguridad dedicados."

LA REALIDAD

Aplica a **cualquier organización** que gestione información sensible o procese datos de terceros: una startup SaaS con 20 empleados, una fintech en crecimiento, una firma de servicios TI con décadas de trayectoria. Lo que varía es el alcance del SGSI, no la exigencia de la norma.

03 · EL MITO

"El proceso tarda años y cuesta demasiado para justificarlo ahora."

LA REALIDAD

Un proceso bien estructurado toma **entre 4 y 6 meses** para una organización mediana. Para una empresa con facturación de \$2M USD anuales, perder un solo contrato corporativo por falta de certificación representa más de **\$200,000 USD en ingresos recurrentes perdidos**. El costo de certificación es una fracción de esa cifra.

Quién debe *certificarse.*

La norma es universal en su diseño, pero no todas las organizaciones tienen la misma urgencia. Algunos sectores en LATAM ya enfrentan consecuencias materializadas —en forma de contratos perdidos, licitaciones bloqueadas o rondas de inversión congeladas— mientras otros están a meses de enfrentarlas.



2.1

ANÁLISIS SECTORIAL

Cinco sectores con mayor urgencia en LATAM

2.2

CRITERIOS MÍNIMOS

Madurez organizacional requerida

2.3

AUTODIAGNÓSTICO

Cinco preguntas sin investigación previa

2.1 · ANÁLISIS SECTORIAL

Los cinco sectores con *mayor urgencia.*

El denominador común: todos gestionan información que impacta directamente a personas o activos de alto valor.

01 · SECTOR FINANCIERO

CNBV / SFC / SBIF

Fintech · Banca · Servicios financieros digitales

Los reguladores ya exigen controles formales; los fondos de capital de riesgo incluyen la certificación como condición vinculante en cierres Serie A y posteriores.

02 · SOFTWARE B2B Y SAAS

52 % DE LAS COMPRAS

Plataformas B2B, ERPs, CRMs, herramientas de productividad

Sin el certificado, la empresa queda descalificada en la primera etapa de filtro, antes de que su propuesta técnica sea siquiera evaluada.

03 · SECTOR PÚBLICO

IMSS · CFE · SAT · GOB

Proveedores de TI para gobierno, integradores, consultoras

Los pliegos de bases técnicas incluyen ISO 27001 como requisito de exclusión obligatorio. Sin el certificado, la empresa ni siquiera puede participar.

04 · SALUD DIGITAL

DUE DILIGENCE

Healthtech, telemedicina, gestión de expedientes clínicos

Los contratos con hospitales privados y aseguradoras en LATAM exigen gobernanza formal de seguridad. Un incidente sin documentación genera responsabilidad civil directa.

05 · SERVICIOS TI

RIESGO TRASLADADO

MSPs, ciberseguridad gestionada, integración de sistemas

Los clientes corporativos trasladan parte de su riesgo al proveedor. La certificación es la única evidencia objetiva de que ese riesgo está gestionado.

2.2 · CRITERIOS MÍNIMOS

¿Está lista *tu* organización?

No todas las organizaciones están listas para iniciar un proyecto ISO 27001 hoy — y eso está bien. La norma tiene requisitos de madurez organizacional mínima que conviene validar **antes de comprometer presupuesto**.

01 TAMAÑO Y ESTRUCTURA

Más de 15 colaboradores con al menos un área formal de IT o Desarrollo. No requiere departamento de seguridad dedicado — sí la estructura mínima para asignar roles de gobernanza.

02 GESTIÓN DE DATOS SENSIBLES

Al menos un sistema o plataforma que procese datos de clientes, empleados o terceros. No basta con "usar herramientas en la nube" sin responsabilidad formal sobre los datos que se gestionan.

03 SPONSOR EJECUTIVO

Un sponsor de nivel directivo (C-Level o reporte directo) con autoridad para impulsar el proyecto, asignar recursos y tomar decisiones sobre el alcance del SGSI.

2.3 · AUTODIAGNÓSTICO RÁPIDO

Cinco preguntas *sin investigación previa.*

Responde mentalmente cada una con sí o no. Suma los "sí" al final.

N °	PREGUNTA
01	¿Tu empresa gestiona datos sensibles de clientes — financieros, de salud, personales o corporativos?
02	¿Tienes documentado formalmente quién tiene acceso a cada sistema y base de datos crítica?
03	¿Existe un proceso establecido para detectar, responder y documentar incidentes de seguridad?
04	¿Cuentas con una política de seguridad de la información aprobada por la alta dirección?
05	¿Has realizado alguna evaluación formal de riesgos de seguridad en los últimos 12 meses?

INTERPRETACIÓN DE RESULTADOS

5 SÍ BASE SÓLIDA
El proyecto te llevará a **formalizar y certificar** lo que ya haces bien. Implementación significativamente más corta.

3–4 SÍ FUNDAMENTOS PARCIALES
Un diagnóstico inicial identificará los **gaps concretos**. Estás en condiciones de iniciar con baja fricción.

1–2 SÍ OPORTUNIDADES
El proyecto te dará los procesos y controles que hoy no tienes. **Impacto en madurez** proporcional al esfuerzo.

0 SÍ URGENTE
Tu organización gestiona información de clientes sin gobernanza formal. No es inusual en LATAM — pero es **urgente atenderlo**.

El costo real de *no certificarse.*

*La mayoría de los directivos evalúa la certificación como un gasto. El análisis correcto es el inverso: calcular cuánto está costando **cada mes** no tenerla.*

3.1 EL FILTRO INVISIBLE

El filtro de descalificación automática

3.2 EL CUELLO DE BOTELLA

60 a 120 horas por cada contrato

3.3 LOS NÚMEROS EXACTOS

El antes y el después

3.1 · EL FILTRO INVISIBLE

La barrera *que no ves venir.*

Los comités de compras y los departamentos de gestión de riesgos de las grandes corporaciones reciben decenas de propuestas cada mes. Ante la imposibilidad operativa de auditar la infraestructura de cada proveedor potencial, implementan un primer filtro con una pregunta estrictamente binaria:

"¿Su organización cuenta con una certificación vigente bajo la norma ISO 27001 emitida por un organismo acreditado?"

Si la respuesta es "no", la solución tecnológica es **descartada de inmediato** — sin importar que posea la interfaz más innovadora, el código más limpio o el precio más competitivo del mercado.

Esta exclusión no ocurre porque el cliente haya identificado un fallo real en tu plataforma. Ocurre porque evaluar y construir un caso de cumplimiento interno para un proveedor no certificado consume demasiado tiempo, especialmente cuando existen alternativas que ya cuentan con el certificado.

EN EL ENTORNO ENTERPRISE

*La falta de certificación equivale a ser catalogado **proactivamente** como un riesgo inasumible.*

3.2 · EL CUELLO DE BOTELLA

60 a 120 horas *por cada contrato.*

Cuando una empresa supera el primer filtro y despierta el interés genuino de un cliente corporativo, el proceso suele verse frenado por el **cuestionario de debida diligencia**: hojas de cálculo o portales con hasta 300 preguntas sobre cifrado, control de accesos, planes de continuidad y gestión de proveedores en la nube.

EN EL DÍA A DÍA

El área de ventas no puede responder preguntas técnicas sobre encriptación. El formulario llega al CTO con urgencia. El CTO dedica entre **40 y 80 horas** de trabajo especializado a rellenar casillas de forma repetitiva — tiempo que debería estar en producto, desarrollo o atención a clientes críticos.

4–12_{sem}

RETRASO EN CICLO

Ciclos de venta retrasados entre 4 y 12 semanas, con la oportunidad enfriándose mientras el cuestionario circula por las bandejas internas.

300_{preg}

DEBIDA DILIGENCIA

Preguntas hiperdetalladas que cada cliente corporativo envía de forma personalizada. Multiplicado por cada prospecto, el costo operativo es enorme.

Al final, ante la presión por cerrar, el equipo técnico envía capturas de pantalla de configuraciones internas como "evidencia" — **comprometiendo la topología real de seguridad** frente a un tercero.

3.3 · LOS NÚMEROS EXACTOS

El antes *y el después.*

VARIABLE OPERATIVA	SIN ISO 27001	CON ISO 27001
Tiempo de respuesta técnica ante prospectos	4 a 12 semanas	1 a 3 semanas (o 2 días hábiles)
Esfuerzo del equipo técnico por contrato	60 a 120 horas	10 a 20 horas
Tasa de cierre en sectores estrictos	30 % – 40 %	70 % – 80 %
Fricción en el embudo de ventas	Bloqueo constante en legal/riesgo	Avance fluido; sello de confianza de marca
Renovaciones con clientes	Nueva auditoría exhaustiva cada vez	Renovación automática con controles anuales

EL HALLAZGO

Para una empresa tecnológica con facturación de **\$2 millones USD** anuales, perder un solo contrato corporativo por falta de certificación representa más de **\$200,000 USD en ingresos recurrentes perdidos.**

El costo de certificación es una **fracción** de esa cifra — y el retorno se alcanza con el primer contrato que el certificado ayuda a desbloquear.

Los controles *que pide la norma.*

*ISO/IEC 27001:2022 estructura su evaluación en dos componentes paralelos: las cláusulas mandatorias de gobernanza y el catálogo operativo de **93 controles del Anexo A**. Lo que sigue es lo que un auditor verifica el día de la auditoría.*



RESUMEN · DOS COMPONENTES DE AUDITORÍA

COMPONENTE	QUÉ EVALÚA
Cláusulas 4 — 10	Gobernanza del SGSI: liderazgo, alcance, riesgos, objetivos, mejora continua.
Anexo A	93 controles operativos en 4 categorías: organizacionales, personas, físicos y tecnológicos.

4.1 · CLÁUSULAS MANDATORIAS

La gobernanza *que el auditor verifica primero.*

Las cláusulas 4 a 10 representan el motor de gobernanza del sistema. El auditor verifica la existencia y operación activa de al menos **16 registros de cumplimiento obligatorio.**

QUÉ EXIGE

Definición formal del alcance del SGSI · Política de Seguridad de la Información aprobada por la alta dirección · Metodología de evaluación de riesgos · Informe de análisis con tratamiento documentado · Declaración de Aplicabilidad (SoA) con justificación de cada control incluido o excluido.

EN EL DÍA A DÍA

*Una empresa SaaS que procesa datos financieros debe poder mostrar al auditor: quién firmó la política, cómo se identificaron los **riesgos críticos**, qué controles se implementaron y por qué.*

Sin estos documentos operando **activamente** — no solo redactados — la auditoría no concluye favorablemente.

4.2 · ANEXO A · CONTROLES OPERATIVOS

93 controles en *cuatro categorías.*

01 · A.5 CONTROLES ORGANIZACIONALES

Políticas corporativas de seguridad, gestión de la relación con proveedores externos, cumplimiento legal y regulatorio integrado.

Qué exige: Políticas formales revisadas periódicamente, clasificación de activos de información, gestión de riesgos en la cadena de suministro tecnológica.

02 · A.6 CONTROLES DE PERSONAS

Competencias técnicas documentadas, términos contractuales de confidencialidad, programas de concientización frente a amenazas como phishing e ingeniería social.

En el día a día: Acuerdos firmados por todo el personal, programa de capacitación con registros, accesos cerrados el mismo día de salida de ex-empleados.

03 · A.7 CONTROLES FÍSICOS

Seguridad de instalaciones, oficinas, centros de datos y perímetros físicos críticos.

Qué exige: Control de acceso físico a áreas donde se procesa información sensible, política de escritorio limpio, gestión de equipos fuera de las instalaciones.

04 · A.8 CONTROLES TECNOLÓGICOS

Seguridad en el ciclo de desarrollo de software, cifrado criptográfico, control de accesos multifactor, monitoreo centralizado de eventos y bitácoras.

En el día a día: Bases de datos cifradas en reposo y tránsito, MFA para acceso a producción, vulnerabilidades detectadas y corregidas dentro de plazos definidos.

4.3 · LAS DOS ETAPAS DE AUDITORÍA

Cómo funciona *el proceso.*

ETAPA 1 REVISIÓN DOCUMENTAL

El auditor verifica que el SGSI esté correctamente diseñado, documentado y que su alcance sea coherente con las actividades reales de la organización. Es la auditoría "de escritorio" que determina si la empresa está lista para la auditoría presencial.

ETAPA 2 AUDITORÍA DE CERTIFICACIÓN

El auditor verifica en campo que los controles documentados en la Etapa 1 estén efectivamente operando en la práctica. Aquí se emiten las no conformidades — mayores o menores — y se determina si procede otorgar el certificado oficial.

LO QUE EL AUDITOR PREGUNTA PRIMERO

*¿Quién aprobó esta política?
¿Dónde está el registro de riesgos?
¿Cómo se monitorean los accesos?
¿Qué pasa cuando ocurre un incidente? ¿A quién le rinde cuentas el responsable de seguridad?*

Si tu organización puede responder estas preguntas con evidencia documentada, la auditoría de certificación está, en sustancia, ganada.

Roadmap de certificación *a 5 meses.*

Así se estructuran típicamente los proyectos de certificación: seis fases con tiempos e hitos. ONCE México certifica el sistema; no lo implementa ni asesora su implementación. Este mapa ayuda a la dirección a dimensionar el esfuerzo antes de iniciar.

DURACIÓN TOTAL: 18 — 24 semanas · Desde el diagnóstico inicial hasta la emisión del certificado.

5.1 · LAS SEIS FASES

01	Diagnóstico inicial (Gap Analysis)	Informe de brechas: qué existe, qué falta, qué requiere crearse. Alcance preliminar del SGSI.	2 — 3 sem
02	Definición del alcance del SGSI	Documento de alcance aprobado: qué sistemas, qué unidades de negocio, qué geografías.	1 — 2 sem
03	Diseño conceptual y documentación	Política aprobada, inventario de activos, estructura documental, evaluación de riesgos, SoA.	4 — 6 sem
04	Implementación operativa de controles	93 controles aplicables operando · personal capacitado · registros de monitoreo · simulacro de incidente probado.	6 — 8 sem
05	Auditoría interna	Informe con hallazgos y plan de correctivas. Organización lista para auditoría externa.	2 sem
06	Auditoría de certificación (3ª parte)	Etapas 1 (documental) y 2 (en sitio). Cierre de no conformidades. Certificado emitido.	3 — 5 sem

Organizaciones con ISO 9001 reducen las Fases 1 y 3 entre 25 y 35 % gracias a la infraestructura documental y de gestión ya existente.

5.2 · PROYECCIÓN DE INVERSIÓN 2026

Lo que cuesta — *y lo que devuelve.*

PERFIL ORGANIZACIONAL	RANGO DE INVERSIÓN TOTAL	DURACIÓN	CONDICIÓN DE PARTIDA
Startup / PyME 15–50 empleados · 2–5 sistemas	\$120 — 200 k MXN	16 — 20 sem	Parte desde cero en gobernanza. ROI vía acceso a contratos corporativos y reducción de fricción en ventas.
Mediana 50–200 empleados · 5–10 sistemas	\$200 — 360 k MXN	18 — 22 sem	Infraestructura técnica existente. ROI vía contratos, licitaciones y mejores condiciones en seguros cibernéticos.
Mediana con ISO 9001 50–200 empleados	\$130 — 240 k MXN	14 — 18 sem	Cultura documental ya instalada. Mismo ROI con inversión incremental significativamente menor.
Grande / Corporativo 200–500+ empleados · 10+ sistemas	\$380 — 650 k MXN	20 — 26 sem	Mayor complejidad interdepartamental. ROI en contratos enterprise e institucionales de alto valor.

5.3 · EQUIPO INTERNO MÍNIMO

El equipo que *se moviliza*.

Responsable del SGSI CISO, Dir. de IT o perfil híbrido	30 – 40 %	Coordina el proyecto, opera el sistema en el largo plazo y aprueba la documentación.
Apoyo Legal	10 – 15 %	Revisión de la política de seguridad y definición de cláusulas contractuales con empleados y proveedores.
Apoyo Técnico IT / DevOps	20 – 35 %	Implementa los controles tecnológicos: accesos, cifrado, monitoreo, gestión de vulnerabilidades.
Sponsor ejecutivo C-Level	Habilitador	Sin respaldo visible, los proyectos mueren en la Fase 3 cuando los equipos técnicos perciben la documentación como una distracción de su trabajo "real".

Cinco objeciones *que matan la decisión.*

La mayoría de los bloqueos no son técnicos. No fallan porque la norma sea difícil ni porque los controles sean imposibles — fallan por decisiones directivas que se toman en las primeras conversaciones y que son muy costosas de revertir después.

01 · LA OBJECCIÓN

"Este trimestre no tenemos presupuesto para esto."

LA SOLUCIÓN PREVENTIVA

El análisis correcto no es el costo del proceso — es el **costo de oportunidad** de postergarlo. Si tu empresa está perdiendo el 40 % del canal de ventas corporativas, cada trimestre de espera tiene un costo financiero directo y calculable.

02 · LA OBJECCIÓN

"Nuestro equipo técnico no tiene tiempo ahora."

LA SOLUCIÓN PREVENTIVA

Hoy el equipo técnico dedica entre 60 y 120 horas por cada cliente corporativo respondiendo cuestionarios improvisados. La certificación reduce ese esfuerzo a **10 — 20 horas** por contrato. El tiempo se recupera con el segundo o tercer cliente.

03 · LA OBJECCIÓN

"Ya tenemos buenos controles. No necesitamos el papel."

LA SOLUCIÓN PREVENTIVA

El mercado corporativo no puede verificar tus controles internos. Solo puede verificar si tienes **un certificado emitido por un organismo independiente acreditado**. La diferencia entre "tenemos buenos controles" y "tenemos el certificado" es la diferencia entre perder y ganar la licitación.

04 · LA OBJECCIÓN

"Vamos a esperar a que sea obligatorio por regulación."

LA SOLUCIÓN PREVENTIVA

Esperar a la regulación es, en sí mismo, una decisión de **riesgo comercial**. Mientras esperas, tus competidores certificados están cerrando los contratos que tú no puedes. Cuando la regulación llegue, ellos ya tendrán tres años de ventaja comercial y operativa.

05 · LA OBJECCIÓN

"Nuestro cliente nunca nos lo ha pedido explícitamente."

LA SOLUCIÓN PREVENTIVA

No te lo piden porque ya tienes el certificado — te lo piden cuando llegan al cuestionario de *due diligence* y descubren que no lo tienes. Para entonces, el daño en la relación comercial ya está hecho. La certificación se presenta **antes de que te la pidan**, como parte del *pitch*.

TABLA RESUMEN · 5 OBJECIONES

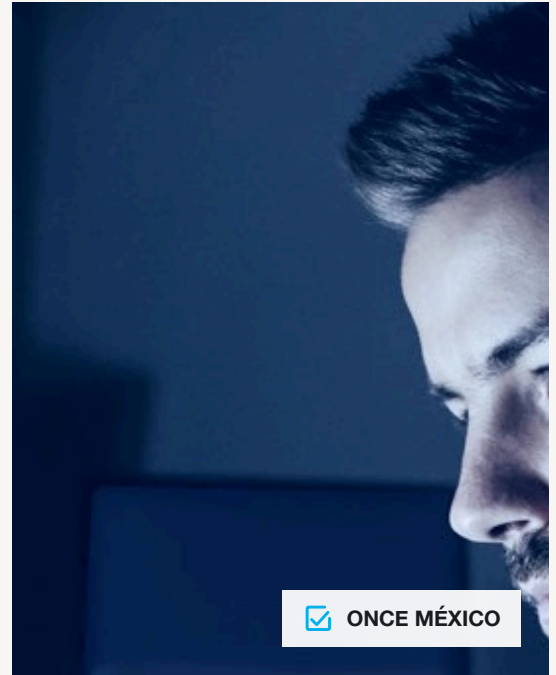
El patrón *visto desde arriba*.

#	OBJECCIÓN	IMPACTO PRINCIPAL	RESPUESTA ESTRATÉGICA
01	Sin presupuesto este trimestre	Postergación indefinida con costo creciente	Calcular el costo de oportunidad vs. el costo de certificación
02	Equipo técnico sin tiempo	60 — 120 h por contrato vs. 10 — 20 h con certificado	El tiempo se recupera con el segundo cliente
03	"Ya tenemos buenos controles"	Invisibilidad ante el comprador corporativo	La evidencia auditada vale más que la confianza declarada
04	Esperar a la regulación	Ventaja competitiva cedida a competidores que actúan primero	Cada mes de espera tiene un costo comercial real
05	"El cliente no nos lo ha pedido"	Descubrimiento tardío en la etapa crítica del proceso de compra	La certificación se presenta antes de que la pidan

07 · CAPÍTULO SIETE

Escenarios ilustrativos *de mercado.*

Tres escenarios representativos contruidos a partir de patrones observados en el mercado. Las organizaciones y las cifras son ilustrativas; no representan clientes específicos ni resultados atribuibles a los servicios de certificación de ONCE México.



CASO 01 · SAAS · GUADALAJARA · 42 EMPLEADOS

Quando el cuestionario de seguridad *congela la venta.*

EL CONTEXTO

Plataforma tecnológica de gestión de cumplimiento normativo con controles técnicos sólidos en AWS. Perdía oportunidades comerciales críticas porque tardaba hasta tres semanas en responder los cuestionarios de seguridad.

EL RETO

Perder una cuenta clave con una aseguradora del top 10 en México — no por precio ni calidad técnica — exclusivamente por carecer del certificado ISO 27001.

LA SOLUCIÓN

Proceso de certificación completado en cinco meses. Superó la auditoría con cero no conformidades mayores. Implementó el envío proactivo del certificado y SoA como primer documento en cualquier proceso comercial.

EN ESTE ESCENARIO ILUSTRATIVO · 8 MESES · CIFRAS ILUSTRATIVAS

\$4.8M

MXN

INGRESOS RECURRENTES

en ingresos anuales directamente atribuibles a la certificación.

2 días hábiles

RESPUESTA TÉCNICA

ante prospectos — vs. tres semanas antes.

5 contratos

CIERRES

corporativos cerrados en los ocho meses posteriores al certificado.

Cero

NO CONFORMIDADES

mayores en la auditoría de certificación.

CASO 02 · SERVICIOS TI · CIUDAD DE MÉXICO · 12 AÑOS DE TRAYECTORIA

La certificación que *abrió el gobierno.*

EL CONTEXTO

Empresa con ISO 9001 y cartera consolidada en el sector privado. Estancada comercialmente por su exclusión automática de licitaciones públicas de gran escala.

EL RETO

IMSS, CFE y dependencias equivalentes incluyen ISO 27001 como condición binaria. Sin el certificado, la empresa ni siquiera puede participar.

LA SOLUCIÓN

Aprovechando la cultura documental existente de ISO 9001, completó la auditoría de certificación en cuatro meses.

EN ESTE ESCENARIO ILUSTRATIVO · 14 MESES · CIFRAS ILUSTRATIVAS

\$8.7M

MXN

INGRESOS GUBERNAMENTALES

acumulados en los primeros 14 meses del certificado.

43%

TASA DE ADJUDICACIÓN

en concursos públicos — vs. el 15 % promedio antes.

35%

DE FACTURACIÓN

pasó a corresponder a contratos gubernamentales en el primer año.

Primera

LICITACIÓN IMSS

ganada — valor \$3.2 M MXN — al mes posterior al certificado.

CASO 03 · FINTECH · MONTERREY · 28 EMPLEADOS

La gobernanza que *desbloqueó la ronda de inversión.*

EL CONTEXTO

Crédito digital para PyMEs en crecimiento. Ronda Serie A con fondos institucionales extranjeros que exigieron evidencia auditada de gobernanza de ciberseguridad.

EL RETO

Sin certificado, el cierre financiero no podía ejecutarse. La CNBV exigía controles formalizados como condición de operación.

LA SOLUCIÓN

Certificación completada en cuatro meses, satisfaciendo simultáneamente CNBV y criterios de los fondos.

\$32M

MXN

RONDA SERIE A

captados en el cierre desbloqueado por la certificación.

6 sem

TIEMPO DE CIERRE

entre la obtención del certificado y el cierre financiero.

CNBV

SATISFECHO

Requerimientos de seguridad satisfechos en paralelo a la certificación.

4 meses

PROCESO TOTAL

de duración del proceso desde el diagnóstico inicial.

La lección compartida: las tres organizaciones esperaron a sufrir una pérdida comercial masiva o un bloqueo crítico de negocio para decidirse a actuar. Esperar tiene un costo real — y ese costo se acumula cada mes.

→ TUS PRÓXIMOS PASOS

La pregunta ya no es *si la necesitas*.

Es cuál es tu siguiente paso concreto — y eso depende del punto en que está tu organización hoy. Elige tu ruta.

El mercado corporativo no va a esperar a que tu organización esté lista para demostrar que protege la información de sus clientes.

Las ventajas competitivas las acumulan los que actúan primero.

RUTA 01

Sesión informativa sobre certificación

30 minutos con nuestro equipo para conocer el proceso de certificación ISO/IEC 27001: sus etapas, requisitos y alcance. Sin costo, sin compromiso.

SIN COSTO

AGENDA TU SESIÓN →

RUTA 02

Foundation · Autoestudio PECB

Curso autogestivo con certificación PECB Foundation en ISO/IEC 27001. Materiales de estudio, evaluación y certificado internacional. Disponible en español.

CERTIFICACIÓN INTERNACIONAL

INSCRÍBETE AHORA →

RUTA 03

Lead Implementer PECB · 4 meses

Programa de formación para profesionales que liderarán la implementación del SGSI en su organización. Impartido por instructores certificados PECB.

CONTACTO DIRECTO

SOLICITA INFORMACIÓN →

La formación y la certificación se mantienen independientes: participar en cursos no influye en las decisiones de auditoría ni de certificación (ISO/IEC 17021-1).

ONCE México · Organismo de certificación especializado en certificaciones de gobernanza de datos, seguridad de la información e IA. **25 años · 200+ organizaciones certificadas en LATAM.**

[ONCEMEXICO.ORG](https://oncemexico.org)

✓ **ONCE**
MÉXICO®